

NOVARA AI, INC.

AI Product Development, Privacy & Governance Policy

Document ID	NAI-POL-0042
Version	3.1
Classification	Confidential — Internal Use Only
Effective Date	1 March 2025
Next Review Date	1 March 2026
Policy Owner	Chief AI Officer
Approved By	Executive Leadership Team

1. Purpose and Scope

This policy establishes Novara AI's mandatory standards for the responsible development, deployment, and ongoing management of artificial intelligence features and products. It applies to all employees, contractors, and third-party partners who design, build, train, evaluate, or operate AI-powered systems on behalf of Novara AI.

The policy covers three interconnected domains:

- AI Product Development — model selection, training data practices, evaluation, and launch criteria
- Privacy & Data Governance — personal data use in AI pipelines, consent, retention, and cross-border transfer
- AI Governance & Risk Management — oversight structures, incident response, external audits, and regulatory compliance

Out of Scope

Internal IT infrastructure not involving AI inference or training (covered by IT Security Policy NAI-POL-0018), and academic research conducted under a separate IRB-approved protocol.

2. Definitions

The following terms have specific meanings throughout this document:

AI System	Any software component that uses machine learning, large language models, computer vision, or similar statistical techniques to generate outputs, recommendations, or automated decisions.
Foundation Model	A large pre-trained model (e.g., a transformer-based LLM or multimodal model) obtained from a third-party provider or trained internally and used as a base for fine-tuning or inference.
High-Risk AI Feature	An AI System that makes or materially influences decisions affecting employment, credit, healthcare, access to services, or legal rights, as further defined in Appendix A.
Training Data	Any dataset used to train, fine-tune, or conduct RLHF/preference-tuning on an AI System, including data sourced from customers, third parties, or Novara AI's own infrastructure.
Personal Data	Any information relating to an identified or identifiable natural person, as defined under GDPR Art. 4(1), UK GDPR, CCPA, and equivalent applicable law.
Red-Teaming	Structured adversarial testing conducted to identify failure modes, safety vulnerabilities, and bias in an AI System prior to production deployment.
Shadow Mode	A deployment configuration where an AI System generates outputs that are logged and reviewed by humans but not surfaced to end users.
Model Card	A standardised documentation artifact describing a model's intended use cases, evaluation metrics, limitations, and known risks.

3. AI Product Development Standards

3.1 Model Selection and Procurement

Prior to integrating any foundation model or third-party AI service, the responsible Product and Engineering team must complete a Model Intake Assessment (template: NAI-TMPL-0031) covering the following:

1. Licensing and intellectual property — confirm the model licence permits commercial use, fine-tuning, and output commercialisation without royalty obligations.
2. Data provenance — obtain the provider's data lineage documentation and assess for known copyright, consent, or PII ingestion issues.
3. Security posture — review SOC 2 Type II report (or equivalent) and confirm the provider's model weights and inference endpoints are covered by an active Business Associate Agreement where applicable.
4. Export controls — verify that deployment to Novara AI's target geographies does not violate U.S. Export Administration Regulations (EAR) or equivalent controls.
5. Performance benchmarks — document accuracy, latency (p50/p99), cost-per-token, and context window on the relevant benchmark suite for the intended task.

The Chief AI Officer (CAIO) must counter-sign Model Intake Assessments for any foundation model that will be used in a High-Risk AI Feature. The CAIO may delegate this authority in writing to the VP of AI Engineering for non-high-risk use cases.

3.2 Training Data Governance

All training datasets — whether sourced internally, from customers, or from third-party data providers — must be registered in Novara AI's centralised Data Catalogue (Collibra instance) prior to use. Registration requires:

- Source and collection method
- Legal basis for use (contract, licence, public domain, or legitimate interest assessment)
- Personal data classification (none / pseudonymised / identified) and applicable retention limit
- Known demographic or geographic skews that may introduce bias
- Data quality score (completeness, consistency, recency) assigned by the Data Engineering team

Prohibited Training Data Sources

Customer content may not be used as training data unless the customer has explicitly opted in via a signed Data Processing Addendum that includes an AI Training Exhibit. Opt-in consent must be recorded in Salesforce CRM and linked from the Data Catalogue entry. Retroactive use of customer data collected before an opt-in was obtained is prohibited regardless of any current contractual status.

Synthetic data generated for training purposes must be documented with the generation methodology, seed prompts (if LLM-derived), and any filtering steps applied. Synthetic data that mimics real customer transactions or communications requires prior approval from the Data Privacy Officer (DPO).

3.3 Model Evaluation Requirements

All AI Systems must pass the following evaluation gates before progressing to each stage of the deployment pipeline:

Gate	Criteria	Artefact Required	Approver
G1: Dev Complete	Unit and integration tests pass; model card drafted; no known P0 safety findings	Model Card v0.1, Test Report	Engineering Lead
G2: Internal Beta	Red-team completed; bias audit completed; latency SLA met in staging; privacy impact assessment signed off	Red-Team Report, DPIA, Bias Audit	CAIO + DPO
G3: Limited GA	Shadow-mode KPIs within $\pm 5\%$ of target; no severity-1 incidents in 14-day observation window	Shadow-Mode Report	Product Lead + CAIO
G4: Full GA	Human-in-the-loop review rate $\leq 98\%$ on sampled outputs; drift monitoring baseline established	Monitoring Dashboard Link	CTO

Evaluation results, including failed iterations, must be retained for a minimum of three years in Novara AI's model registry (MLflow). Records may not be deleted or anonymised prior to expiry, even if the corresponding model is deprecated.

3.4 Red-Teaming and Safety Testing

Every AI System must undergo a structured red-team exercise before Gate G2. Red-teaming must be conducted by a team that did not build the model under review. For High-Risk AI Features, at least one red-teamer must be external to Novara AI (a contracted third-party security or AI safety firm).

Red-team scope must include, at minimum:

- Prompt injection and jailbreak resistance
- Generation of harmful, illegal, or defamatory content
- Demographic bias and discriminatory output across protected characteristics (race, gender, age, disability, religion, national origin, sexual orientation)
- Hallucination rate on factual queries relevant to the product domain
- PII leakage from training data or context windows

Red-team findings must be triaged using Novara AI's AI Risk Severity Matrix (NAI-DOC-0017). All P0 (Critical) and P1 (High) findings must be resolved or formally risk-accepted by the CAIO before Gate G2 approval is granted.

3.5 Human-in-the-Loop Requirements

AI Systems that produce outputs that are directly acted upon by customers or that influence consequential decisions must maintain a meaningful human-in-the-loop (HITL) mechanism. HITL implementations are classified as follows:

- Level 1 — Mandatory Human Review: All AI outputs are reviewed and approved by a qualified human operator before delivery. Required for High-Risk AI Features in healthcare, legal, and financial verticals.
- Level 2 — Sampled Review: A statistically significant random sample (minimum 5% or 500 outputs per week, whichever is greater) is reviewed. Required for all other High-Risk AI Features.
- Level 3 — Exception-Based Review: Outputs flagged by automated confidence scoring or policy filters are escalated for human review. Permitted for standard AI Features with documented justification.

The applicable HITL level must be specified in the product's Model Card and confirmed at Gate G2. Downgrading the HITL level post-launch requires CAIO approval and a DPIA update.

4. Privacy and Data Protection

4.1 Legal Basis and Purpose Limitation

Novara AI processes personal data in AI pipelines only where a valid legal basis exists under the applicable data protection law for each processing jurisdiction. Acceptable bases are:

6. Contract performance — where processing is strictly necessary to deliver a contracted service feature.
7. Legitimate interest — where Novara AI has conducted and documented a Legitimate Interest Assessment (LIA) confirming that its interests are not overridden by data subject rights.
8. Explicit consent — required for any use of personal data in model training or for sharing inference outputs with third parties not covered by the original service agreement.

Personal data collected for one purpose may not be repurposed for AI training or evaluation without a separate legal basis assessment. Product Managers must document purpose scope in the DPIA at project inception.

4.2 Data Minimisation and Pseudonymisation

AI pipelines must be designed to minimise personal data ingestion. Specifically:

- Inference requests must not log raw personal data beyond the minimum retention period necessary for debugging and safety review (default: 30 days; see Section 4.4).
- Training datasets containing personal data must be pseudonymised before use. Direct identifiers (name, email, national ID, IP address) must be removed or tokenised using a reversible key stored in a separate access-controlled vault.
- Where pseudonymisation is technically not feasible (e.g., face-recognition training datasets), explicit consent and a DPIA signed by the DPO are required before ingestion.
- Embeddings generated from personal data are considered personal data and must be subject to the same retention and deletion controls as the source data.

4.3 Data Subject Rights in AI Contexts

Novara AI's standard data subject rights procedures (NAI-POL-0009) apply to all AI-processed personal data. In addition, the following AI-specific obligations apply:

Right to Explanation	Where an AI System makes or significantly influences a decision affecting a data subject, the subject may request a plain-language explanation of the factors that influenced the output. Product teams must implement an explanation endpoint within 90 days of GA launch.
Right to Object to Automated Profiling	Data subjects may opt out of AI-driven profiling that produces legal or similarly significant effects. Product teams must implement a documented opt-out mechanism and ensure the flag is propagated to all downstream inference pipelines within 72 hours.
Right to Erasure	Deletion requests must cascade to: (a) production inference logs, (b) fine-tuning datasets containing the subject's data, and (c) embedding stores. Where technical constraints prevent deletion from a fine-tuned model, machine unlearning

Right to Rectification	techniques must be evaluated; if not feasible, the model must be retrained or retired within the applicable statutory deadline.
	If a data subject's correction of underlying data would materially alter past AI outputs (e.g., a credit risk score), affected downstream records must be flagged for human review.

4.4 Retention and Deletion

Default retention periods for AI-related data are as follows. These periods may be shortened but not extended without DPO approval:

Data Category	Retention Period	Notes
Inference request/response logs (no PII)	12 months	Extendable to 24 months for safety investigations
Inference logs containing PII	30 days	Requires DPO sign-off to extend beyond 30 days
Training dataset (pseudonymised)	Duration of model lifecycle + 3 years	Deletion required within 30 days of model retirement
Model weights (production)	Duration of deployment + 5 years	Supports audits, rollback, and legal holds
Red-team and evaluation reports	5 years	Subject to litigation hold extensions
DPIA and LIA records	3 years post-processing cessation	Regulatory inspection requirement
Embedding vectors (personal data)	Same as source data	Enforced via automated pipeline tagging

4.5 Cross-Border Data Transfers

Where AI inference or training workloads involve the transfer of personal data outside the European Economic Area (EEA) or United Kingdom, the following transfer mechanisms must be in place before data is transmitted:

- Adequacy decision (where applicable, e.g., UK-US data bridge for qualifying transfers)
- Standard Contractual Clauses (SCCs) — EU 2021/914 Module 2 (controller-to-processor) or Module 3 (processor-to-processor) as appropriate
- Transfer Impact Assessment (TIA) completed and on file

Novara AI's primary AI inference regions are us-east-1 (N. Virginia) and eu-west-1 (Ireland). Customer data classified as EEA-residency-required must be processed exclusively in eu-west-1. This restriction must be enforced at the infrastructure level via data residency tags in Terraform and verified quarterly by the Infrastructure Security team.

5. AI Governance Structure

5.1 Governance Roles and Committees

Novara AI's AI governance is organised across three layers: executive accountability, operational oversight, and embedded team-level responsibility.

Role / Committee	Responsibilities	Meeting Cadence
Chief AI Officer (CAIO)	Ultimate accountability for AI policy compliance, model risk appetite, and regulatory engagement. Signs off on High-Risk AI Feature launches and material policy exceptions.	—
AI Ethics & Safety Committee	Cross-functional committee (CAIO, DPO, VP Legal, VP Product, Head of Engineering, 2 independent external advisors) responsible for policy updates, escalated incident review, and annual external audit commissioning.	Monthly; ad hoc for P0 incidents
Data Privacy Officer (DPO)	Reviews and approves DPIAs and LIAs; serves as point of contact for regulatory authorities; advises on data subject rights fulfilment in AI contexts.	Weekly sync with AI team leads
AI Safety Review Board	Technical sub-committee (VP AI Eng., Lead ML Safety Researcher, 2 rotating senior engineers) responsible for red-team oversight, bias audit sign-off, and monitoring threshold-setting.	Bi-weekly
Product AI Champions	Embedded role within each product squad. Accountable for completing Model Intake Assessments, maintaining model cards, and escalating risks to the AI Safety Review Board.	Per-sprint

5.2 Risk Register and Classification

The AI Risk Register (maintained in Jira, project: AI-RISK) is the authoritative record of all identified AI-related risks. Risks are classified using a 4×4 likelihood–impact matrix. The following categories are tracked:

Risk Category	Description	Mitigation Owner	Review Cadence
Model Safety	Harmful, biased, or factually incorrect outputs reaching end users	CAIO / AI Safety Review Board	Bi-weekly
Privacy / Regulatory	Unlawful processing of personal data in AI pipelines; cross-border transfer violations	DPO	Monthly
IP & Copyright	Training data containing unlicensed third-party IP; outputs reproducing copyrighted material	VP Legal	Quarterly
Third-Party Model Risk	Supply-chain risk from foundation model providers: deprecation, API changes, safety regressions	VP AI Engineering	Monthly

Risk Category	Description	Mitigation Owner	Review Cadence
Operational Reliability	Model degradation, concept drift, latency SLA breach	Head of SRE	Weekly
Adversarial / Abuse	Prompt injection, jailbreaking, or misuse by malicious actors to generate harmful content	Head of Security	Continuous

5.3 Incident Response

AI-related incidents are managed within Novara AI's standard incident management process (NAI-POL-0021) with the following AI-specific additions:

Severity Definitions

- P0 (Critical): AI System produces outputs that cause or risk causing material harm to users or third parties; data breach involving AI-processed personal data; systemic bias causing discriminatory impact on a protected class.
- P1 (High): Significant hallucination rate increase detected in production; single high-severity harmful output incident; HITL bypass discovered.
- P2 (Medium): Localised accuracy degradation below SLA thresholds; minor bias patterns identified in monitoring; customer complaint regarding AI explainability.
- P3 (Low): Documentation gaps; minor policy non-compliance without user impact; near-miss events.

Response Timelines

- P0: CAIO notified within 15 minutes of detection; AI System suspended or placed in Level 1 HITL mode within 1 hour; DPO notified within 2 hours; preliminary incident report filed within 24 hours; regulatory notification (where required) within 72 hours.
- P1: CAIO notified within 2 hours; remediation plan within 24 hours; full post-mortem within 5 business days.
- P2: Assigned to AI Safety Review Board within 24 hours; resolution within 14 days.
- P3: Logged in AI Risk Register; reviewed at next bi-weekly AI Safety Review Board meeting.

Post-Incident Review

All P0 and P1 incidents require a blameless post-mortem within 5 business days of resolution. Post-mortems must be reviewed by the AI Ethics & Safety Committee and archived in Confluence (space: AI-SAFETY). Recurring patterns across post-mortems must be escalated to the CAIO for systemic remediation.

5.4 External Audits and Regulatory Compliance

Novara AI commissions an independent third-party AI audit annually, with scope covering:

- Compliance with this policy and ISO/IEC 42001:2023 (AI Management System)
- GDPR / UK GDPR Article 22 (automated decision-making) compliance

- EU AI Act obligations applicable to Novara AI's risk classification (confirmed by Legal as 'Limited-Risk' for current product portfolio, subject to annual re-assessment)
- SOC 2 Type II Trust Services Criteria as they apply to AI processing activities

Audit findings must be reported to the Board of Directors within 30 days of receipt. A remediation plan for material findings must be approved by the CAIO and submitted to the auditor within 60 days.

Novara AI monitors regulatory developments in the following frameworks on a quarterly basis and updates this policy as required: EU AI Act implementing acts, UK AI regulation proposals, U.S. NIST AI RMF updates, FTC AI guidance, and sector-specific regulations applicable to customer verticals (finance, healthcare, HR tech).

6. Responsible AI Principles

All AI development at Novara AI must be guided by the following principles, which are operationalised through the standards in Sections 3–5:

- **Beneficence** — AI Systems must be designed to deliver measurable value to users and must not be optimised for engagement at the expense of user wellbeing.
- **Non-maleficence** — Foreseeable harms must be systematically identified, mitigated, and accepted only at a risk level explicitly approved by the CAIO.
- **Fairness** — AI Systems must not produce discriminatory outputs. Bias audits are mandatory, and demographic parity, equalised odds, or other appropriate fairness metrics must be monitored continuously in production.
- **Transparency** — Users must be informed when they are interacting with AI-generated content or AI-influenced decisions. Model cards must be maintained and made available to enterprise customers upon request.
- **Accountability** — Every AI System in production must have a named accountable owner. Ownership must transfer when personnel change and must be reflected in the model registry within 5 business days.
- **Privacy by Design** — Privacy considerations must be embedded from the earliest stages of AI product design, not retrofitted after build.
- **Human Oversight** — Novara AI will not deploy AI Systems that are designed to operate without any possibility of human intervention or override.

7. Training and Awareness

All employees with a role in AI development, product management, or data science must complete the following training:

AI Ethics Foundations (NAI-LRN-0041)	Annual; all employees involved in AI product work. Covers bias, fairness, transparency, and this policy. Duration: 90 minutes. Completion tracked in Workday.
Data Privacy in AI Pipelines (NAI-LRN-0042)	Annual; mandatory for engineers, data scientists, and product managers. Covers GDPR/UK GDPR, DPIA process, and data minimisation. Duration: 60 minutes.
Secure AI Development (NAI-LRN-0043)	Annual; mandatory for ML engineers and MLOps. Covers adversarial ML, prompt injection defences, and model supply chain security. Duration: 75 minutes.
Red-Team Practitioner (NAI-LRN-0044)	One-time certification for designated red-team members. Covers structured red-teaming methodology, bias audit techniques, and report writing. Duration: 4 hours.

Training completion rates are reported to the AI Ethics & Safety Committee quarterly. Employees who are non-compliant after a 30-day grace period will be escalated to their line manager and People Operations.

8. Policy Exceptions

Requests to deviate from any mandatory requirement in this policy must be submitted via the AI Policy Exception Request form (NAI-FORM-0019) to the CAIO. Each request must include:

- The specific policy clause for which an exception is sought
- Business justification and the intended duration of the exception
- Compensating controls that will be in place for the duration
- Risk assessment signed by the requesting team's VP

Exceptions are time-bounded (maximum 90 days, renewable once) and must be logged in the AI Risk Register. The CAIO may involve the AI Ethics & Safety Committee for exceptions that could materially affect user safety or regulatory compliance. No exception may be granted that would place Novara AI in violation of applicable law.

9. Enforcement and Consequences

Violations of this policy may result in disciplinary action up to and including termination of employment or contract, depending on severity and intent. Violations that result in harm to users or regulatory breaches will be referred to Novara AI's Legal team and, where required, reported to relevant regulatory authorities.

Employees who identify potential violations are encouraged to report them via Novara AI's confidential Ethics Hotline (ethics@novara.ai or the anonymous Vault platform). Retaliation against good-faith reporters is strictly prohibited and constitutes a separate policy violation.

10. Document Control and Review

This policy is reviewed annually by the CAIO in consultation with the AI Ethics & Safety Committee, and updated as needed in response to material changes in technology, product offering, or regulatory landscape. Ad hoc reviews may be triggered by:

- A P0 incident
- A material change in the EU AI Act or other applicable regulation
- Acquisition or launch of a new AI capability that is not covered by existing policy

All versions are maintained in Novara AI's document management system (Confluence, space: POLICY). Version history must be preserved. Superseded versions are archived and marked 'Retired' but remain accessible for audit purposes.

v1.0 — June 2022	Initial release. Authors: CAIO, DPO, VP Legal.
v2.0 — January 2024	Added EU AI Act alignment section; expanded red-teaming requirements; updated cross-border transfer provisions for UK GDPR post-Brexit.
v3.0 — September 2024	Introduced HITL level classification; added model supply chain provisions; revised training curriculum.
v3.1 — March 2025	Minor amendments: updated retention schedule for embedding vectors; clarified machine unlearning obligations; added ethics hotline reference.

Appendix A — High-Risk AI Feature Criteria

An AI System is classified as a High-Risk AI Feature if it meets any of the following criteria:

- 9. The system’s outputs directly inform or substitute for a human decision that affects an individual’s access to employment, promotion, or performance evaluation.
- 10. The system scores, ranks, or profiles individuals for credit, insurance, or financial product eligibility.
- 11. The system generates clinical recommendations, diagnostic suggestions, or treatment plans in a healthcare context.
- 12. The system is used by a customer in a regulated industry (financial services, healthcare, legal) to produce outputs that are provided to end clients.
- 13. The system processes biometric data (facial recognition, voice identification, keystroke dynamics) for authentication or identification.
- 14. The system is used to generate, curate, or rank content that will be seen by more than 1 million users per month (large-scale recommender systems).
- 15. Legal or Compliance determines that the system falls within scope of the EU AI Act Annex III high-risk categories.

Classification is determined at Gate G1 by the Product AI Champion in consultation with Legal and the DPO. Borderline cases are escalated to the CAIO.

Appendix B — Related Policies and Documents

Document ID	Title	Owner
NAI-POL-0009	Data Subject Rights Procedure	DPO
NAI-POL-0018	IT Security Policy	CISO
NAI-POL-0021	Incident Management Policy	Head of Engineering
NAI-TMPL-0031	Model Intake Assessment Template	VP AI Engineering
NAI-DOC-0017	AI Risk Severity Matrix	CAIO
NAI-FORM-0019	AI Policy Exception Request Form	CAIO
NAI-LRN-0041–44	AI Training Curriculum	People Operations

END OF DOCUMENT

NAI-POL-0042 v3.1 • © 2025 Novara AI, Inc. All rights reserved. Confidential — Internal Use Only.